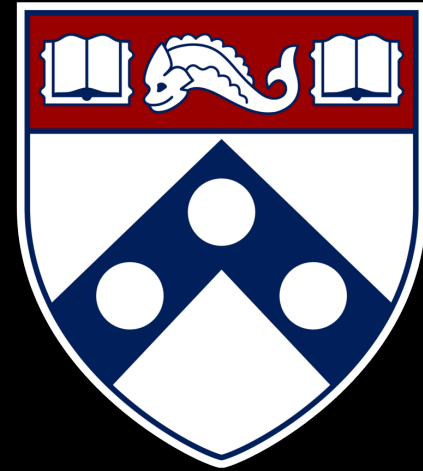


Empirical Security & Privacy, for Humans



UPenn CIS 7000-010
10/21/2025



The
Building Security In
Maturity Model (BSIMM)

Readings

Building Security In Maturity Model



FOCUS: SOFTWARE ENGINEERING'S 50TH ANNIVERSARY

Engineering

a security breach.¹⁻⁴ Yet, breaches are reported daily in the news in all domains—from the casual to the critical. Research in 2017

From: Alex Gantman agantman@qti.qualcomm.com
Subject: RE: BSIMM - what is the value?
Date: October 12, 2025 at 11:56 PM
To: Michael Hicks mwh@cis.upenn.edu

AG

Hi Mike,

It's ... complicated. 2000+ words of nuance, history, and rambling follow. Enjoy 🤔

TL;DR: It was very useful to us 15 years ago, but I haven't looked at it the last decade or so. It may be most useful to a recently formed security team at a mid-sized company. Here's a slide I put together in 2015, after our last BSIMM assessment:

What BSIMM is not

- BSIMM is not a "how to" guide
 - Not prescriptive; doesn't tell you what to do or how to do it.
- BSIMM is not a measure of performance
 - or effectiveness, security, etc.
 - Doesn't tell you if you are doing something well
- BSIMM is not "best practices"
 - It is "actual practices"
- It may tell you that you are doing many of the same activities as everyone else
 - But it will not tell you whether you are doing them well
 - Or whether doing them at all has any impact on the security of the product

BSIMM can be viewed as several things. It was Gary McGraw's baby, and I think what he was trying to achieve with it was highly valuable. Gary thought that instead of making up an ideal secure development process, he should elicit the set of practices from the people who practice them! So, Gary, together with Sammy Migue and Brian Chess, interviewed software security teams at 9 large companies. That became the first version of BSIMM. I highly recommend this 2010 talk by Gary McGraw for getting a sense of how he positioned it at the time: <https://www.youtube.com/watch?v=SI-MJbvn9-mQ>. But it was also a marketing tool for his employer, and I have less favorable

In 2008, software security was a young field

← → ↺ wired.com/2002/01/bill-gates-trustworthy-computing/ ☆ 🔍 📁 📧 👤 ⋮

≡ **WIRED** 🔍 NEWSLETTERS SUBSCRIBE

***THIS IS THE** e-mail Bill Gates sent to every full-time employee at Microsoft, in which he describes the company's new strategy emphasizing security in its products.*From: Bill Gates
Sent: Tuesday, January 15, 2002 5:22 PM
To: Microsoft and Subsidiaries: All FTE
Subject: Trustworthy computing

January 2002

Every few years I have sent out a memo talking about the highest priority for Microsoft. Two years ago, it was the kickoff of our .NET strategy. Before that, it was several memos about the importance of the Internet to our future and the ways we could make the Internet truly useful for people. Over the last year it has become clear that ensuring .NET is a platform for Trustworthy Computing is more important than any other part of our work. If we don't do this, people simply won't be willing -- or able -- to take advantage of all the other great work we do. Trustworthy Computing is the highest priority for all the work we are doing. We must lead the industry to a whole new level of Trustworthiness in computing.

Microsoft
secure software
DEVELOPMENT SERIES

BEST PRACTICES

THE SECURITY DEVELOPMENT LIFECYCLE

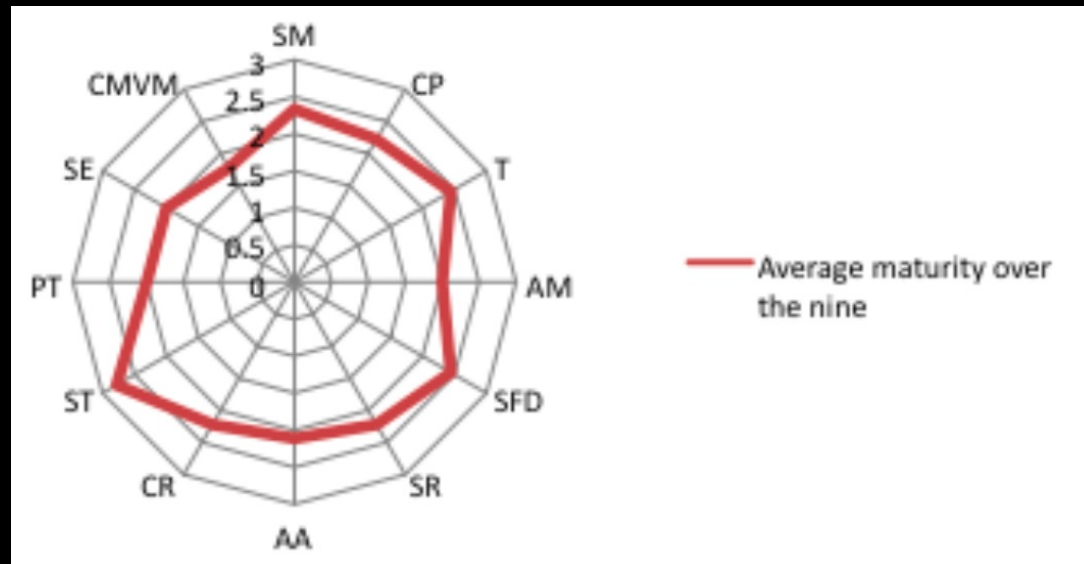
July 2006



SDL: A Process for Developing Demonstrably More Secure Software

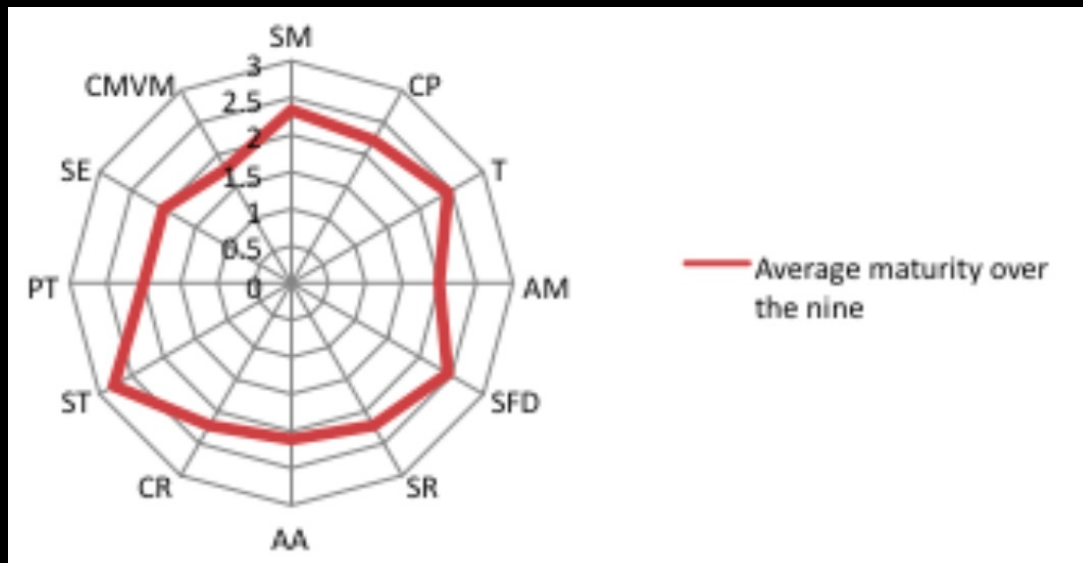
BSIMM arrived in early 2009. What was it?

“Our aim with BSIMM is to **document the activities common** to all of the **leading software security initiatives**”

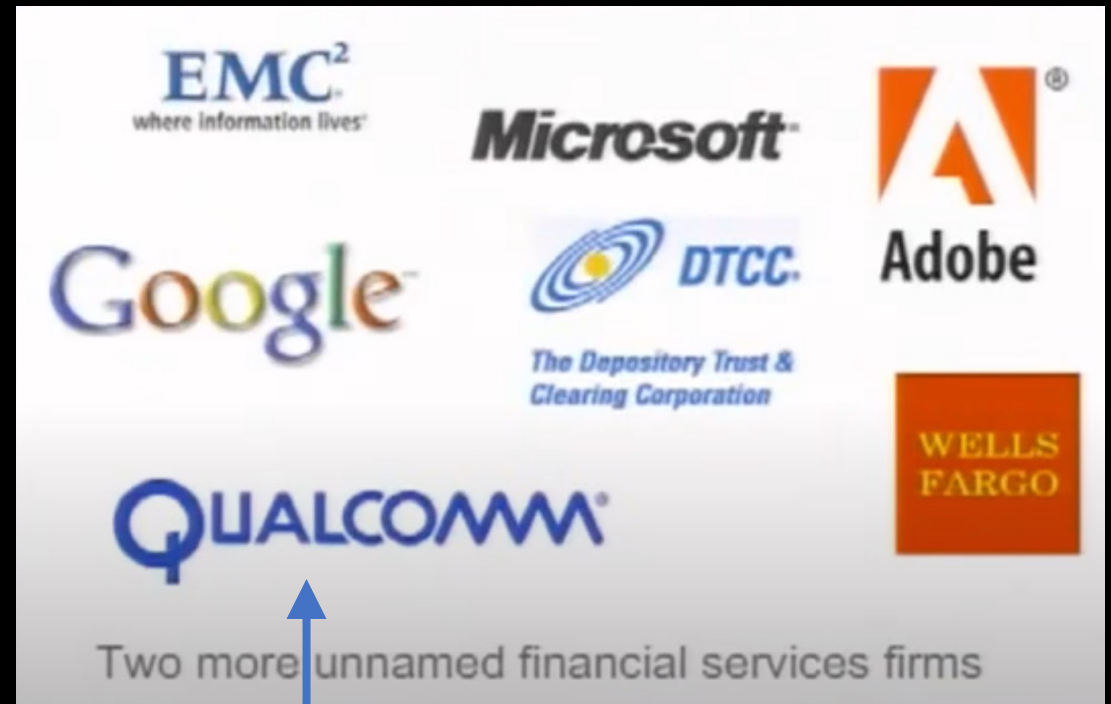


BSIMM arrived in early 2009. What was it?

“Our aim with BSIMM is to **document the activities common** to all of the **leading software security initiatives**”



Subjects: 9 large companies



Alex Gantman, now VP of Security Engineering, directly participated



What BSIMM is not

Slide written in 2015



- BSIMM is not a “how to” guide
 - Not prescriptive; doesn’t tell you what to do or how to do it
- BSIMM is not a measure of performance
 - Or effectiveness, security, etc.
 - Doesn’t tell you if you are doing something well
- BSIMM is not “best practices”
 - It is “actual practices”
- It may tell you that you are doing many of the same activities as everyone else
 - But it will not tell you whether you are doing them well
 - Or whether doing them at all has any impact on the security of the product

How was the BSIMM constructed?

1. Interviews	An investigator carries out a multi-hour interview with each participant.
2. Coding	Each investigator creates twelve “bullet lists” for each of the nine organizations, one bullet list for each practice identified by the <i>Software Security Framework</i> (SSF).
3. Unification	Investigators fuse practice lists for each company into per-practice lists for all companies; note prevalence.
4. Leveling	Investigators rate maturity level of each individual practice, given its difficulty and context.

What is the Software Security Framework?

The Software Security Framework (SSF)			
Governance	Intelligence	SSDL Touchpoints	Deployment
Strategy and Metrics	Attack Models	Architecture Analysis	Penetration Testing
Compliance and Policy	Security Features and Design	Code Review	Software Environment
Training	Standards and Requirements	Security Testing	Configuration Management and Vulnerability Management

What data is in the BSIMM?

110 activities among the 12 practices, categorized into three levels. Ex:

GOVERNANCE: TRAINING			
	Objective	Activity	Level
[T1.1]	promote culture of security throughout the organization	provide awareness training	1
[T1.2]	ensure new hires enhance culture	include security resources in onboarding	
[T1.3]	act as informal resource to leverage teachable moments	establish SSG office hours	
[T1.4]	create social network tied into dev	identify satellite during training	
[T2.1]	build capabilities beyond awareness	offer role-specific advanced curriculum (tools, technology stacks, bug parade)	2
[T2.2]	see yourself in the problem	create/use material specific to company history	
[T2.3]	keep staff up-to-date and address turnover	require annual refresher	
[T2.4]	reduce impact on training targets and delivery staff	offer on-demand individual training	
[T2.5]	educate/strengthen social network	hold satellite training/events	
[T3.1]	align security culture with career path	reward progression through curriculum (certification or HR)	3
[T3.2]	spread security culture to providers	provide training for vendors or outsource workers	
[T3.3]	market security culture as differentiator	host external software security events	

What data is in the BSIMM?

110 activities among the 12 practices, categorized into three levels. Ex:

GOVERNANCE: TRAINING			
	Objective	Activity	Level
[T1.1]	promote culture of security throughout the organization	provide awareness training	1
[T1.2]	ensure new hires enhance culture	include security resources in onboarding	
[T1.3]	act as informal resource to leverage teachable moments	establish SSG office hours	
[T1.4]	create social network tied into dev	identify satellite during training	
[T2.1]	build capabilities beyond awareness	offer role-specific advanced curriculum (tools, technology stacks, bug parade)	2
[T2.2]	see yourself in the problem	create/use material specific to company history	
[T2.3]	keep staff up-to-date and address turnover	require annual refresher	
[T2.4]	reduce impact on training targets and delivery staff	offer on-demand individual training	
[T2.5]	educate/strengthen social network	hold satellite training/events	
[T3.1]	align security culture with career path	reward progression through curriculum (certification or HR)	3
[T3.2]	spread security culture to providers	provide training for vendors or outsource workers	
[T3.3]	market security culture as differentiator	host external software security events	

Establish SSG office hours. The SSG offers help to any and all comers during an advertised lab period or regularly scheduled office hours. By acting as an informal resource for people who want to solve security problems, the SSG leverages teachable moments and *emphasizes the carrot over the stick*. Office hours might be held one afternoon per week in the office of a senior SSG member.

How, per its motivation, is BSIMM scientific?

- BSIMM doesn't develop predictive theories based on reality, like physics. It categorizes observations, like **anthropology** (or ethnography).
- "BSIMM is a collection of good ideas and activities that are in use today ... BSIMM provides waypoints like a trail guide rather than recipes like a cookbook."



But
beware:

Gary pulls a bit of a sleight of hand when positioning BSIMM as "science" in contrast to "faith-based" or "cargo cult" approaches. It may be a scientific(ish) anthropological study of practices, but those practices themselves remain faith-based. It's like surveying the average height of cargo-cult wood radio tower imitations or length of fallow runway replicas, which wouldn't get us any closer to the science of air travel.

BSIMM is
qualitative
research

It codes a model for how
companies carry out software
security initiatives

The Coding Manual for Qualitative Researchers

»»» 3E «««

Johnny
Saldaña

 SAGE

Los Angeles | London | New Delhi
Singapore | Washington DC

BSIMM supports the market for silver bullets?

- Security is hard to assess
 - Leads to information insufficiency
- Investment decisions not based on good metrics, but rather on *signals*
 - “best practices”
- If cost of breaches > cost of products, **all parties herd around the same products**

https://iang.org/papers/market_for_silver_bullets.html

<i>The Market for Goods, as described by Information and by Party</i>	Buyer Knows	Buyer Lacks H1
Seller Knows	Efficient Goods	Lemons (used cars)
Seller Lacks H2	Limes (Insurance)	Silver Bullets (Security)

“By using the SSF and BSIMM as a guide for your own software security initiative, you can leverage the many years of experience captured in the model.”— BSIMM1

“But there was another use for BSIMM. How can I demonstrate progress to the higher ups if I am operating in a market for silver bullets?” – Alex G.

Coincidence?

Gary's Silver Bullet Security Podcast ran from 2006 to 2018

‘The name of the podcast is an inside joke reference to Fred Brooks’ famous paper “No Silver Bullet – Essence and Accidents of Software Engineering”’

← → ↻ 🔍 garymcgraw.com/technology/silver-bullet-podcast/ ☆

SILVER BULLET SECURITY PODCAST

The Silver Bullet Security Podcast with Gary McGraw was published once a month for thirteen and a half years. The series started in April 2006 and ended in December 2018. This is a permanent archive of episodes. The podcast features in-depth conversations I had with fellow security gurus. Guests included technologists, academics, business people, authors, the press, and government officials. Since its inception, episodes of Silver Bullet have been downloaded many millions of times. On average, each episode has accumulated over 13,000 listeners.

The name of the podcast is an inside joke reference to Fred Brooks’ famous paper “**No Silver Bullet — Essence and Accidents of Software Engineering**.” There was once no silver bullet, now there is.



THE SILVER BULLET
SECURITY PODCAST
WITH GARY McGRAW

IEEE
SECURITY & PRIVACY

synopsys®

Silver Bullet Special Video Episode 120

 Silver Bullet Security Podcast Episode 120 - Video

Watch later Share



Observed commonalities, BSIMM1

Ten Core Activities Everybody Does		
	Objective	Activity
[SM1.2]	build support throughout organization	create evangelism role/internal marketing
[CP1.3]	meet regulatory needs or customer demand with a unified approach	create policy
[T1.1]	promote culture of security throughout the organization	provide awareness training
[T1.2]	see yourself in the problem	create/use material specific to company history
[SFD1.1]	create proactive security guidance around security features	build/publish security features (authentication, role management, key management, audit/log, crypto, protocols)
[AA1.3]	build internal capability on security architecture	have SSG lead review efforts
[CR2.1]	drive efficiency/consistency with automation	use automated tools along with manual review
[ST2.1]	use encapsulated attacker perspective	integrate black box security tools into the QA process (including protocol fuzzing)
[PT1.1]	demonstrate that your organization's code needs help too	use external pen testers to find problems
[SE1.2]	provide a solid host/network foundation for software	ensure host/network security basics in place

SSG = centralized Software Security Group. Observed to be 1% the number of developers

Three Core Activities that Most Organizations Do		
	Objective	Activity
[AM1.4]	understand the organization's history	collect and publish attack stories
[SR1.1]	meet demand for security features	create security standards
[CMVM1.2]	use ops data to change dev behavior	identify software bugs found in ops monitoring and feed back to dev

BSIMM over time

- More companies, with more verticals represented
- Avg dev/SSG team size shrunk
- More experienced companies carried less weight

	BSIMM9	BSIMM8	BSIMM7	BSIMM6	BSIMM-V	BSIMM4	BSIMM3	BSIMM2	BSIMM1
FIRMS	120	109	95	78	67	51	42	30	9
MEASUREMENTS	320	256	237	202	161	95	81	49	9
2ND MEASURES	42	36	30	26	21	13	11	0	0
3RD MEASURES	20	16	15	10	4	1	0	0	0
4TH MEASURES	7	5	2	2	0	0	0	0	0
SSG MEMBERS	1,600	1,268	1,111	1,084	0	0	0	0	0
SATELLITE MEMBERS	6,291	3,501	3,595	2,111	976	978	786	635	370
DEVELOPERS	415,598	290,582	272,782	287,006	272,358	218,286	185,316	141,175	67,950
APPLICATIONS	135,881	94,802	87,244	69,750	69,039	58,739	41,157	28,243	3,970
AVG. SSG AGE (YEARS)	4.13	3.88	3.94	3.98	4.28	4.13	4.32	4.49	5.32
SSG AVG. OF AVGS	1.33 / 100	1.60 / 100	1.61 / 100	1.51 / 100	1.40 / 100	1.95 / 100	1.99 / 100	1.02 / 100	1.13 / 100
FINANCIAL SERVICES	50	47	42	33	26	19	17	12	4
ISVs	42	38	30	27	25	19	15	7	4
TECH	22	16	14	17	14	13	10	7	2
HEALTHCARE	19	17	15	10					
INTERNET OF THINGS	16	12	12	13					
CLOUD	17	16	15						
INSURANCE	10	11	10						
RETAIL	10								

From BSIMM9 report

Table 1. Vulnerability prevention practices.

Problem	Practice	Usage (%)
Bugs (2)	Use a top- <i>N</i> bugs list (real data preferred).	21
	Use secure coding standards.	14
	Average (bugs)	18
Flaws (28)	Build and publish security features.	78
	Translate compliance constraints to requirements.	65
	Engage a software security group (SSG) with architecture.	64
	Create a data classification scheme and inventory.	62
	Unify regulatory pressures.	61
	Create security standards.	61
	Create (security) policy.	51
	Gather and use attack intelligence.	46
	Create an SSG capability to solve difficult design problems.	38
	Identify potential attackers.	33
	Implement and track controls for compliance.	32
	Use application containers.	27
	Identify a personally-identifiable-information data inventory.	25
	Create standards for technology stacks.	23
	Identify open source in apps.	23
	Define and use an architectural-analysis process.	13
	Build and maintain a top- <i>N</i> possible attacks list.	13
	Standardize architectural descriptions (including dataflow).	11
	Require use of approved security features and frameworks.	10
	Build attack patterns and abuse cases tied to potential attackers.	8
	Create technology-specific attack patterns.	7
	Build a capacity for eradicating specific bugs from the entire code base.	5
	Form a review board to approve and maintain secure design patterns.	5
	Have a science team that develops new attack methods.	4
	Make the SSG available as an architectural-analysis resource or mentor.	2
	Have software architects lead design review efforts.	2
	Find and publish mature design patterns from the organization.	2
	Drive analysis results into standard architecture patterns.	0
	Average (flaws)	28
	Average usage of all 30 practices	27

BSIMM8 observations

Table 2. Vulnerability detection practices.*

Problem	Practice	Usage (%)
Bugs (10)	<i>Use external penetration testers to find problems.</i>	87
	Ensure that quality assurance (QA) supports edge or boundary value condition testing.	80
	Have the SSG perform an ad hoc review.	63
	<i>Use penetration testing tools internally.</i>	62
	Use automated tools along with a manual review.	60
	Make code review mandatory for all projects.	31
	<i>Integrate black-box security tools into the QA process.</i>	23
	Perform fuzz testing customized to application APIs.	9
	<i>Include security tests in QA automation.</i>	8
	<i>Create and use automation to do what attackers will do.</i>	1
	Average for bugs	42
Flaws (11)	<i>Use external penetration testers to find problems.</i>	87
	Perform a security feature review.	83
	<i>Use penetration testing tools internally.</i>	62
	Perform a design review for high-risk applications.	28
	<i>Integrate black-box security tools into the QA process.</i>	23
	Have the SSG lead design review efforts.	22
	Use automated tools with tailored rules.	15
	<i>Include security tests in QA automation.</i>	8
	Build a factory. (Multiple analysis techniques feed into one reporting or remediation process.)	3
	Automate malicious-code detection.	3
	<i>Create and use automation to do what attackers will do.</i>	1
	Average for flaws	30
	Average use of all 16 practices (duplicate practices removed)	36

* Italics indicate practices that appear for both bugs and flaws.

Table 3. Vulnerability response practices.

Practice	Usage (%)
Create or interface with incident response.	84
Track software bugs found in operations through the fix process.	76
Have an emergency code base response.	72
Use application input monitoring.	45
Use application behavior monitoring and diagnostics.	4
Fix all occurrences of software bugs found in operations.	4
Average	48

- 7 prevention practices are used by more than half the firms; more motivated by compliance than impact? Could firms better use their SSG for prevention?
- Pen testing, external and internal, extremely popular
- In general, more activities followed for detection rather than prevention – implies reactive rather than proactive security?
- For response, few firms use app behavior monitoring – missed opportunity?

NIST SSDF – Collecting best practices today

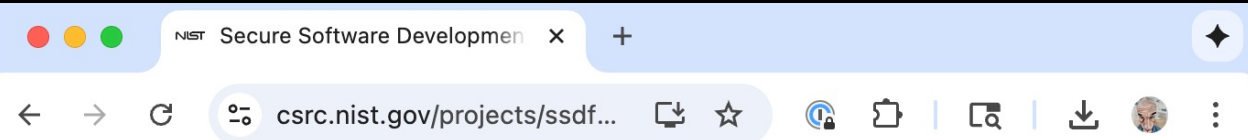
NIST Special Publication 800-218

Secure Software Development Framework (SSDF) Version 1.1:

Recommendations for Mitigating the Risk of Software Vulnerabilities

The intention of the SSDF is **not to create a checklist to follow**, but instead to provide a **basis for planning and implementing a risk-based approach to adopting secure software development practices** and continuously improving software development.

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-218>



SSDF Use

The SSDF can help an organization to align and prioritize its secure software development activities with its business/mission requirements, risk tolerances, and resources. The SSDF's practices are outcome-based. Comparing the outcomes an organization is currently achieving to the SSDF's practices may reveal gaps to be addressed. An action plan to address these gaps can aid in setting

s and its risk

considered when
to each practice.
practices at scale.
ertain

The SSDF's practices, tasks, and implementation examples represent a starting point to consider; they are meant to be changed and customized, and to evolve over time. The intention of the SSDF is not to create a checklist to follow, but instead to provide a basis for planning and implementing a risk-based approach to adopting secure software development practices and continuously improving software development.

Why did we even bother

Slide written in 2015



3 BSIMM assessments for 3 different reasons

- 2009
 - First inventory of software security activities across multiple industries
 - Eye-opening, therapeutic
 - Created a community of product security professionals
- 2011
 - Re-measurement
 - Attempt to evaluate progress
 - Disappointing checklist approach
- 2015
 - Required to remain in BSIMM community
 - Third party assessment
 - Marketing

“Being able to refer to the behavior of the rest of the herd is great as **long as you are trailing and trying to catch up.** The problem comes when you have caught up and **try to lead.**”

Discussion

- What BSIMM practices/SSF areas did you find interesting?
 - Which ones might most easily transfer from big companies to smaller ones?
 - What do you make of the trends observed in BSIMM1 and the IEEE paper?
- The paper claims that BSIMM will help achieve the following – do you believe it?
 - Informed risk management decisions
 - Clarity on the “the right thing to do” for those involved in software security
 - Cost reduction through standard, repeatable processes
 - Increased code quality
- What do you think about the BSIMM development methodology? Tweaks or improvements possible?
 - E.g., they did not use open coding, nor take steps toward calibrating judgment
- What is the relevance of BSIMM today? How could we improve it?
 - How might you measure the impact of particular practices?
 - How does it relate to DevSecOps? How does it apply to small companies?